



UNIVERSIDAD SANTO TOMÁS SECCIONAL TUNJA

Facultad de ingeniería de sistemas

ANÁLISIS CON BURP SUITE

ESPACIO ACADEMICO:

Ciberseguridad Blue Team y White hat

PRESENTADO A:

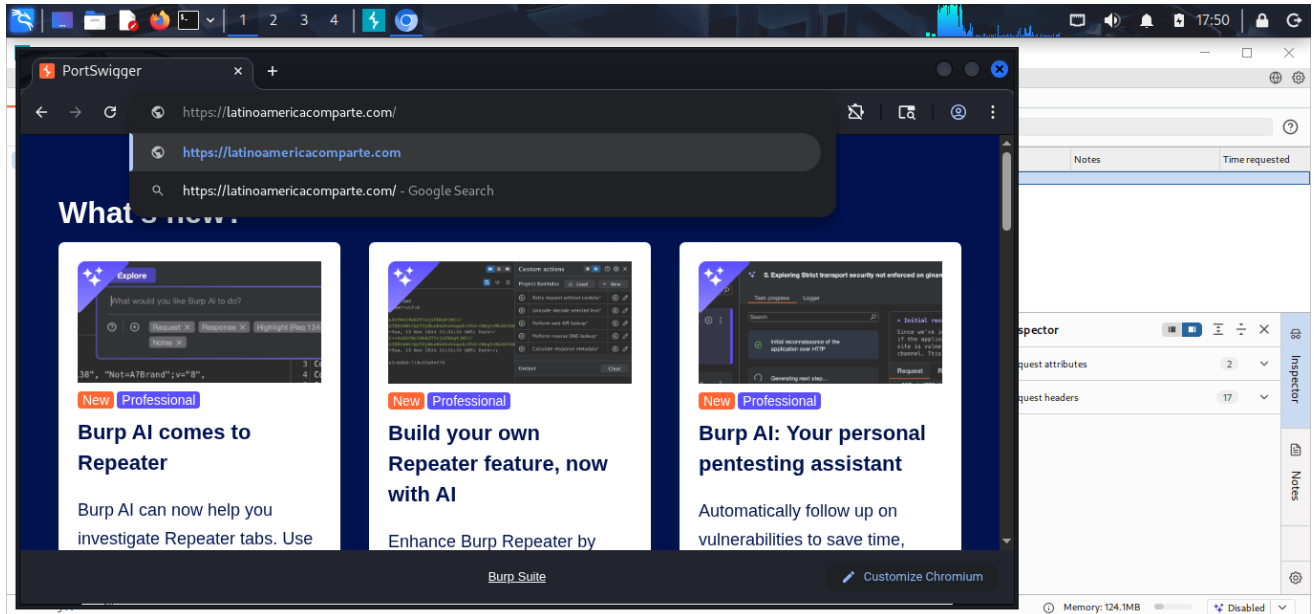
Sergio Arley Puerto Moreno

AUTORES:

Arcila Pulido Julián Andrés
Bayona Garavito Juan Pablo
Galindo Rodríguez Manuel Felipe
García Niño Michael Steven
Gómez David Fernando

1.

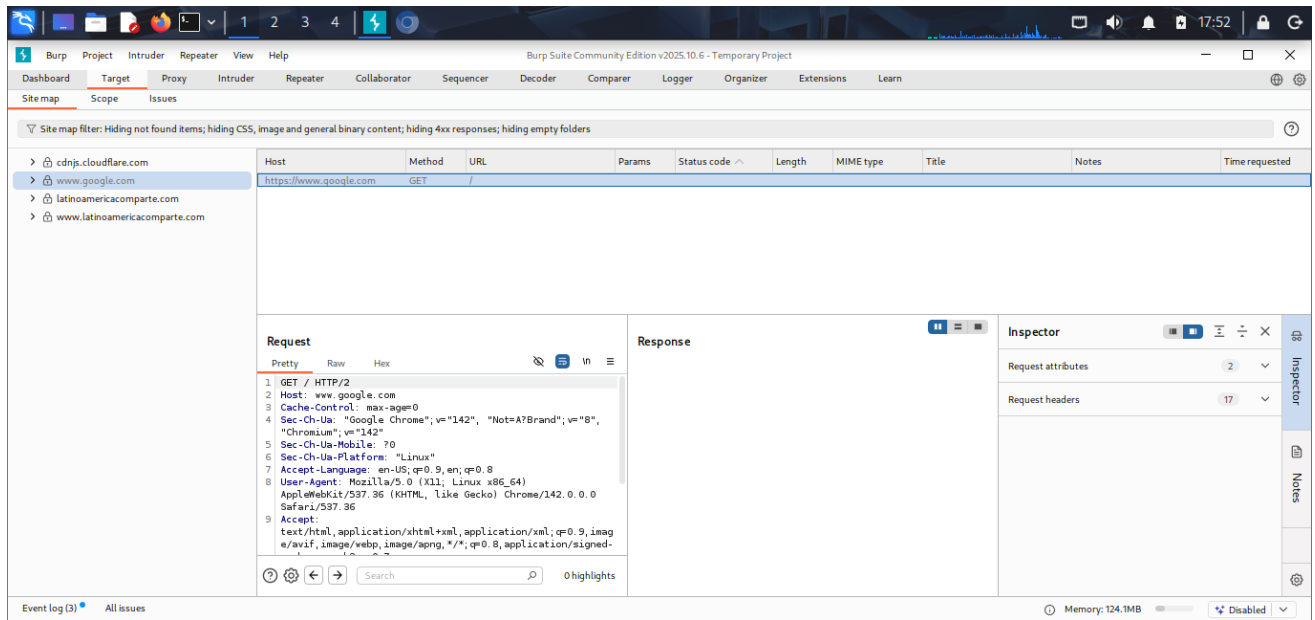
Para empezar con la auditoría de la página **latinoamericacomparte.com**, abrimos Burp Suite Community Edition en nuestro entorno de Kali Linux. En lugar de complicarnos configurando proxies externos en el sistema, utilizamos la herramienta nativa **Burp Browser** (un navegador Chromium que ya viene listo y preconfigurado por PortSwigger para mandar todo el tráfico directamente a Burp).



2.

Con el proxy escuchando de fondo, navegamos por el sitio web para que Burp Suite descubra de forma automática la estructura de carpetas, archivos, scripts y dependencias de la plataforma.

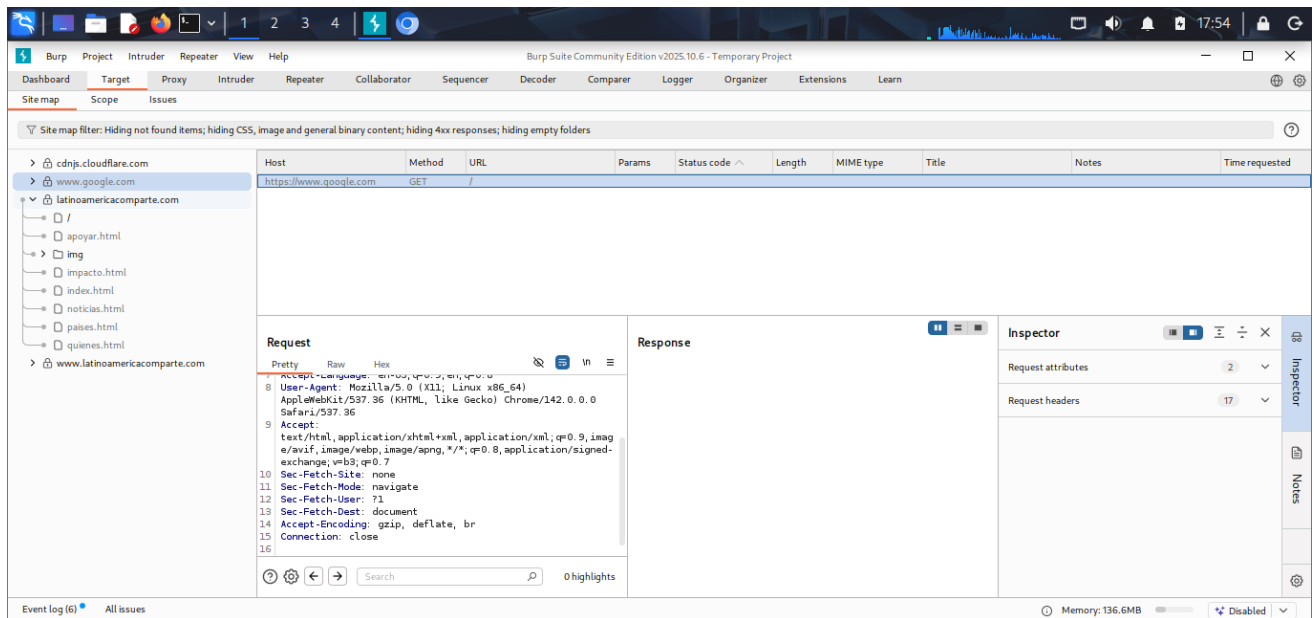
Al expandir el árbol de directorios a la izquierda, nos damos cuenta de que el mapa del sitio ya no está vacío. Burp Suite indexó con éxito el dominio principal y detectó conexiones en segundo plano hacia servicios externos críticos, como las librerías de JavaScript alojadas en el CDN de Cloudflare (cdnjs.cloudflare.com).



3.

El punto clave de este laboratorio fue analizar la pestaña **Response** (Respuesta del servidor) para ver qué tan protegido está el servidor web frente a conexiones de usuarios reales.

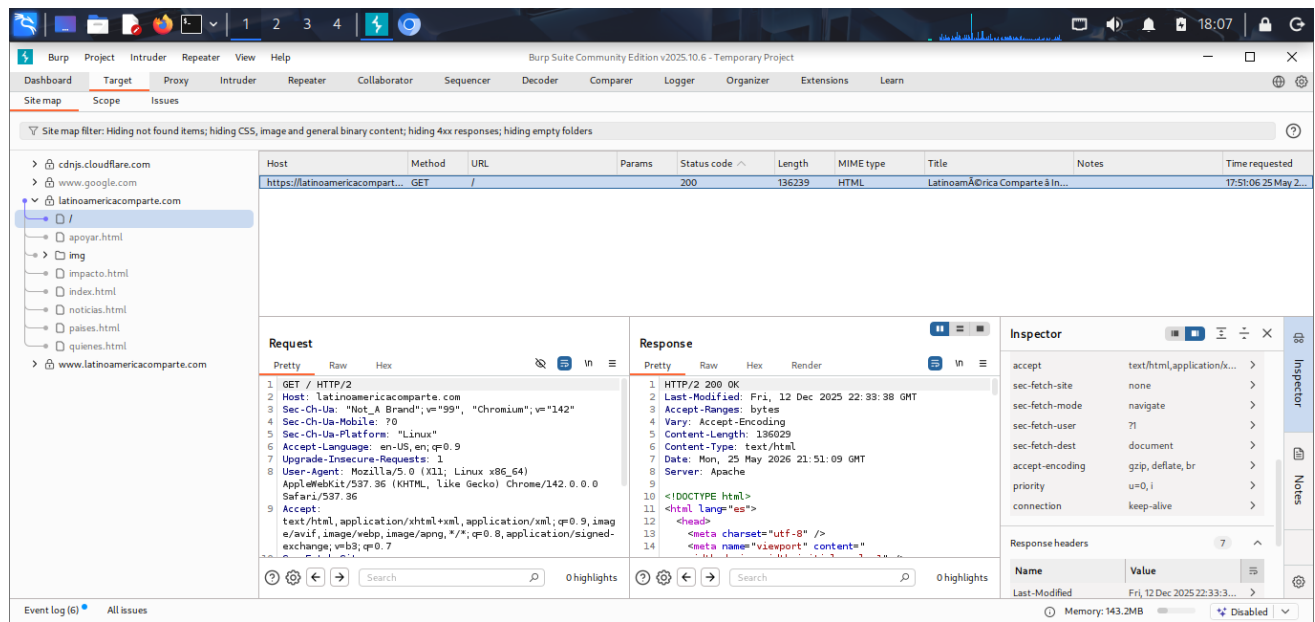
Usamos el panel lateral derecho de Burp Suite para que nos organizara los encabezados de forma cómoda.



Seleccionamos la petición principal (GET /) de latinoamericacomparte.com para auditar sus metadatos directamente en las líneas de respuesta.

The screenshot shows Burp Suite with the 'Target' tab selected. The site map on the left shows a tree structure with 'cdnjs.cloudflare.com' and 'www.google.com' as root nodes. Under 'cdnjs.cloudflare.com', there is a sub-tree for 'www.latinoamericacomparte.com' containing files like 'apoyar.html', 'img', 'impacto.html', 'index.html', 'noticias.html', 'países.html', and 'quienes.html'. The main table displays a request to 'https://cdnjs.cloudflare.com' with method 'GET' and URL '/ajax/libs/animejs/3.2.1/anime...'. The response is a JavaScript file (MIME type: script) with status code 200. The 'Request' and 'Response' tabs are visible, showing the raw data. The 'Inspector' tab on the right shows the response headers, including 'Content-Type: application/javascript; charset=utf-8' and 'Server: cloudflare'.

The screenshot shows Burp Suite with the 'Target' tab selected. The site map on the left shows a tree structure with 'cdnjs.cloudflare.com' and 'www.google.com' as root nodes. Under 'cdnjs.cloudflare.com', there is a sub-tree for 'www.latinoamericacomparte.com' containing files like 'apoyar.html', 'img', 'impacto.html', 'index.html', 'noticias.html', 'países.html', and 'quienes.html'. The main table displays a request to 'https://latinoamericacomparte.com' with method 'GET' and URL '/'. The response is an HTML document (MIME type: HTML) with status code 200. The 'Request' and 'Response' tabs are visible, showing the raw data. The 'Inspector' tab on the right shows the response headers, including 'Content-Type: text/html', 'Date: Mon, 25 May 2026 21:51:09 GMT', and 'Server: Apache'.



- Fuga de Información (Server: Apache): En la línea 8 de la respuesta se ve claramente que el servidor le avisa a cualquiera que usa Apache. Esto es un riesgo de reconocimiento pasivo, porque un atacante ya sabe qué tipo de vulnerabilidades específicas ir a buscar.
- Ausencia de HSTS (Strict-Transport-Security): No aparece esta cabecera por ningún lado. Significa que el servidor no obliga al navegador a usar HTTPS de forma estricta, quedando expuesto a ataques de red como SSL Strip (degradación de canales seguros).
- Ausencia de Protección contra Clickjacking (X-Frame-Options): Al no estar configurada, cualquier atacante podría meter esta página web dentro de un marco invisible (iframe) en otro sitio web falso para engañar a la gente y robar sus clics.
- Ausencia de X-Content-Type-Options: Tampoco está mitigado el MIME sniffing, lo que podría permitir que el navegador confunda un archivo malicioso con un recurso estático (como una imagen o texto) y lo termine ejecutando.